

BOB-102-round6-remediation

BOB-102 — round-6 remediation of the CM-LAN- ROUTES-AUTHENTICATED gate

Revision: 1 **Last modified:** 2026-08-26T16:26:57Z **Author label:**
(T11/002-user-owned-downloads - milos85vasic - ? - xhigh)

Round-5 verdict remediated: NO-GO — 2 IMPORTANT / 4

MINOR / 3 NIT **Artifacts:** scripts/pre_build/

lan_route_auth_analyzer.py, tests/pre_build/

test_check_cm_lan_routes_authenticated.sh, docs/scripts/

check_cm_lan_routes_authenticated.md (+ .html/.pdf/.docx twins)

0 — The primitive this round fixed was a CLAIM, not a regex

Findings expanded $1 \rightarrow 1 \rightarrow 9$ across rounds 3–5 because each review attacked a surface the previous one had not. Per §11.4.250 the recurring shape named the defective primitive, and it was not in any regex: the shipped docstring and guide asserted “**the DROPS column is empty; any future entry in this column is a release blocker.**” That is unearnable by inspection (§11.4.118 — absence of evidence of looking is not evidence of absence) and it promoted every not-yet-discovered idiom into a standing release blocker.

The claim is RETRACTED in both the analyzer docstring and the guide, and replaced with the enumerated-set / method / honest-gap form. The DROPS column stays and stays filled in honestly; only the completeness assertion is gone.

1 — Reproduced before fixed (§11.4.199), then fixed

#	defect	pre-fix measurement	closure
F1	gin .Use on a dotted receiver credits a same-named local engine	mutating route auth_wired=true, findings 0, exit 0	(?<![\w.]) on GIN_USE
F2a	router.post("/p")(fn) immediate call	route vanished, exit 0	router-attribute rule
F2b	@router.route("/p", methods=[...])	route vanished, exit 0	route added to refused decos
F2c	@router.post("/p") on a ClassDef	route vanished, exit 0	router-attribute rule
F2d	reg = router.post then @reg("/p")	route vanished, exit 0	router-attribute rule
A1	gomux dotted receiver inherits a local mux's wrap	mutating route auth_wired=true, exit 0	MUX_DOTTED_OWNER refusal
A2	two gin engines sharing a name across functions	both routes auth_wired=true, exit 0	engines keyed per declaration SITE
A3	re-assigned FastAPI router back-credits earlier routes	unguarded route auth_wired=true, exit 0	refuse a router bound >once
F4	gin selector split across lines (r. / POST())	route dropped, exit 0	selector-continuation refusal

F2b was verified against the **installed** FastAPI (routing.py:1317, 102 lines above the api_route round 5 cited). route calls add_route() → a plain starlette Route that dependency injection never runs on, so Depends can never reach it; it is refused permanently, never modelled.

A1-A3 were found by this round's own credit audit, not by the review.

2 — Credit-bearing-construct audit, all three extractors

Rule applied: *a credit must never be attributed across a scope boundary the resolver cannot see.*

extractor	construct	verdict
gin	GIN_USE	LEAK — fixed (F1)
gin	engines (multi-engine refusal)	LEAK — fixed (A2)
gin	GIN_GROUP dotted	measured fail-closed — no fix
gin	GIN_ENGINE	refusal-side only
gomux	MUX_ROUTE owner	LEAK — fixed (A1)
gomux	MUX_DECL dotted	measured fail-closed — no fix
gomux	<code>_carriers / GO_ASSIGN</code>	lhs anchored bare → fail-closed
fastapi	router_authed	LEAK — fixed (A3)
fastapi	guard_aliases	hardened earlier; module-name collision measured fail-closed (refused with a finding)
fastapi	handler/decorator dependencies	node-local, no aliasing surface

3 — The reviewer's F2 remedy shape was NARROWED, and why

The suggested rule (“refuse any Call whose `func.attr ∈ HTTP_METHODS ∪ {route}` outside modelled decorator position”) **could not ship as written**: `.get` is both an HTTP verb and the most common method name in Python, so it fires on `d.get(k)`, `os.environ.get(k)`, `requests.post(...)` — the §11.4.201(1) false-positive machine. The shipped rule additionally requires the **owner to be a router the module declared**. `fastapi-verbnames-not-routers` is the fixture that holds it to that, and it dies under mutation **G1** (owner qualification removed).

4 — The pin sweep: measuring my own replacement claim

The retraction asserts “every REFUSES verdict is pinned by a fixture that dies when the refusal is removed.” Rather than assert it, it was **measured** by deleting each refusal in a scratch copy. **Six survived** — websocket_route, gin .Match, gin .NoRoute, http.DefaultServeMux, unknown service kind, exemption missing path. All six are now pinned and each pin re-verified to die under the deletion. The DefaultServeMux fixture initially **could not fail** (the route resolved unauthenticated either way); an exemption was added so the refusal is the only thing that can make it exit 1.

5 — §1.1 mutation matrix (all against byte-verified scratch copies)

Kill direction — every new rule is load-bearing:

N5 drop websocket from refused set refused <- the round-5 SURVIVOR	KILLED	fastapi-websocket-
M1 drop route from refused set	KILLED	fastapi-route-deco
M2 GIN_USE lookbehind removed false-safe	KILLED	gin-dotted-use-
M3 MUX_ROUTE lookbehind removed MUTANT (see below)	SURVIVED - PROVEN EQUIVALENT	
M4 remove gomux dotted refusal false-safe	KILLED	gomux-dotted-recv-
M3+M4 combined false-safe	KILLED	gomux-dotted-recv-
M5 gin engines back to by-NAME same-name	KILLED	gin-two-engines-
M6 remove selector-continuation continuation	KILLED	gin-selector-
M7 remove router re-assign refusal reassign	KILLED	fastapi-router-
M8 remove router-attribute rule classdef, bound-alias)	KILLED	x3 (immediate-call,
P1..P6 the six formerly-unpinned refusals	ALL NOW KILLED by	their new fixtures

M3 is an equivalent mutant, not a gap:

MUX_DOTTED_OWNER refuses and continues before MUX_ROUTE is consulted, so the lookbehind is unreachable defence. The pair is load-bearing as a unit — M3+M4 together is killed.

False-positive direction (§11.4.201(1)) — every guard is RED-capable:

G1 router-attr: drop owner qualification verbnames-not-routers	KILLED	fastapi-
G2 GIN_USE: kill all credit still-credits (+7)	KILLED	gin-bare-use-
G3 MUX dotted: over-broad recv-still-credits (+11)	KILLED	gomux-bare-
G4 continuation: fire on any trailing dot continuation-not-a-route (sole killer)	KILLED	gin-
G5 engines: refuse on ONE site two-funcs (+7)	KILLED	gin-one-engine-
G6 router re-assign: fire always level-deps-ok (+4)	KILLED	fastapi-router-

6 — MINORs / NITs

- **F5** digest recipe — the docstring now carries the **exact commands** that regenerate both the 106 and the 19, and pins the scan list itself (19 paths = 8 .py + 11 .go, sha256 head c7a793a0021c3804).
- **F6** the multi-statement refusal's boundary is now **owned** in-source (it is deliberately wider than its motivating defect; a single registration whose ; sits in a closure body is refused conservatively) and pinned by gin-semicolon-in-closure-body so narrowing it later is deliberate.
- **F7** refusals now print a **per-decorator reason** (`_DECO_REFUSAL_REASON`) instead of "websocket routes are not modelled" for `api_route/route`.
- **F8** the dotted-receiver check moved **above** the non-literal-path check, so a `}`-preceded dotted receiver is refused under the truthful label.
- **F9** for owner, `raw` in `MUX_ROUTE.findall(ln) → mux_path`; the shadow of the file-lines `raw` is gone.

7 — Do-not-regress (all re-run this round)

```

harness                93 passed, 0 failed    (was 63; +30
fixtures) x3 deterministic,
                        verdict-stream sha 2794ed7597175549
identical across all three runs
real tree              74 routes / 3 services / 23 known-gaps /
PASS, exit 0, stderr 0 bytes
real tree --json md5    ecd4b31c2f40c87ed321a00c43cacb26
(UNCHANGED - byte-identical)
go lexical census      106 files, 0 lex gaps, 0 odd separators,
class-matched needles seeing
py_compile             CLEAN (no SyntaxWarning)
bash -n               CLEAN (gate + harness)

```

```
residue gate                scanned 272 file(s); 0 hit(s); 1 audited
waiver(s); exit 0
                             (the waiver is
check_cm_export_charset_valid.sh:46 - a SIBLING's)
PDF twin                    0 mojibake; needles $ x23, - x50 present;
retraction text present
guide twins                  .html/.pdf/.docx all regenerated, mtimes
>= .md
```

The digest did not move, as predicted by a pre-change exposure scan (zero multi-engine gin files, zero selector continuations, zero dotted mux receivers, zero router attributes outside decorator position in the real policy roots) whose own detectors were control-needle-proven before the zeros were trusted.

8 — Not closed / honestly open

- **The gate still asserts static WIRING, never runtime ARMING.** BOBA_API_TOKEN is unset by default, so statically-protected routes are open on a default deploy. Tracked as **BOB-197** (boot-time invariant, §11.4.254). Unchanged by this round and not claimed covered.
- **fastapi module-basename collision** across packages is measured fail-closed today (the guard-alias multi-binding rule catches it) but that is incidental rather than designed. Recorded, not fixed.
- **The enumerated set is a sample, not a proof.** That is the point of §0: an idiom outside it is un-surveyed, not proven absent.
- `pre_build_verification.sh` was NOT run — T042 owns it.